

Tata Steel Sessions — Full Narrator Script

2026-09-19 · prepared by @Anand Jayaraman

This compiles the speaker notes from both decks into one continuous script, organised by section rather than slide number, so it reads as a talk rather than a slide list. Each heading names the slide(s) it covers; on-slide text isn't repeated, only what to say and do.

Two things changed after the original client thread surfaced. The split is 90 minutes for Session 1 and 60 for Session 2, per Willem Ypma's 2 September email, so Session 2 runs tighter and its pacing notes say so. And the audience spans India, the Netherlands and the UK, which adds a regulatory slide to Session 1 (31 slides), and the hybrid joining format reshaped the exercise into a two-case guided discussion and makes NIS2 the anchor of Session 2's closing third.

Read this once before the day, then carry the decks into the room; every slide still has its own notes for a glance mid-sentence. Items marked NEEDS CONFIRMATION should be checked with the client team before delivery.

Session 1 — AI Governance for IT Audit

Cold Open (Slides 1-4)

Opening (Slide 1). Good afternoon. Over the next ninety minutes we're going to cover three things that are really one thing: how to audit the AI systems already running at Tata Steel, how you as auditors can use AI to do your own jobs better, and the governance frame that ties both together. This session is built specifically for Kalinganagar and for this audit function, not a generic AI briefing.

Agenda (Slide 2). Walk through this in under a minute. Say plainly: this is built for a ninety-minute working session with this room, not a lecture. If a topic sparks real discussion, we stay there. Think of this as a menu, not a script.

The 680+ stat (Slide 3). Open with Tata Steel's own facts, not a generic AI-101 framing. These two figures are public record and verified: 680+ live applications, and Kalinganagar's 2019 WEF Global Lighthouse designation. Say it plainly to the room: this plant has been a global reference site for AI in manufacturing for seven years. Pivot line: an organisation running 680 applications on a plant like that has outgrown "do we trust AI" as a question.

The pivot question (Slide 4). Ask the room directly and hold the number. Come back to it at the close of the session. The point isn't to catch anyone out; it's to make the gap between adoption and audit coverage visible early, honestly, before we get into the

framework.

Thread A — Auditing AI Systems (Slides 5-17)

Section open (Slide 5). Transition into the first thread: what does an actual audit program for AI and agentic systems look like, built from real failure patterns rather than theory.

Four things people call "AI" (Slide 6, optional). A grounding slide, included because the audience spans India, the Netherlands and the UK and AI exposure across those teams is unlikely to be even. Skip it without comment if the room is clearly fluent; two minutes if not. It also serves the "AI and agentic AI foundation" item from Protiviti's original proposal without turning the session into AI 101. The closing line is the working point: project names say "AI" regardless of which of the four is underneath, and the audit approach differs completely between them. The agentic row sets up the three questions covered later.

PO scope-creep story (Slide 7). This is a composite scenario built from a pattern seen across manufacturing deployments, used here to introduce the three questions that follow, not presented as a live Tata Steel incident. Land the point slowly: no single person made a conscious decision to expand this agent's authority. It happened through individually reasonable adjustments, which is exactly why it's hard to catch after the fact. These three questions are the actual starting audit program for any agentic deployment, not a preamble to one.

Four-question test + blast furnace win (Slide 8). This four-question sequence, in this order and no other, is the antidote to deploying AI because a demo looked good. Business strategy first, then the decision engine, then workflow fit, and only then AI relevance. NEEDS CONFIRMATION FLAG: the blast furnace and pellet plant figures are drawn from a public Tata.com feature, not from a direct client conversation. They are favourable, precise numbers, worth a two-line check with Sachin, Vaibhav, or the client team before they're read aloud as fact. If unconfirmed by the session date, soften to "reported publicly at" rather than stating as settled.

Two-layer audit program (Slide 9). Most audit functions already have reasonable frameworks for the data layer; that part isn't new. The gap tends to be in the model and deployment layers, because explainability, defined performance thresholds, and drift monitoring rarely make it into go-live audit scope. Practical test for the room: was a performance baseline documented at deployment, with a monitoring mechanism that flags deviation from it? If not, the original sign-off was incomplete.

Accountability photo slide (Slide 10). The vendor built the model. The data team trained it. The business unit deployed it. IT hosts it. The "model owner," if that role exists on paper at all, is usually a junior analyst who was never told they'd be accountable for anything. When something goes wrong, accountability becomes a coordination problem spread

across four or five functions, none of whom feels fully responsible. This is exactly where the deployment and accountability layer just covered earns its keep: naming an owner before something goes wrong, not after.

Apple Card / Goldman Sachs (Slide 11). What actually converted this into a regulatory crisis wasn't the underlying bias; plenty of models have bias issues that get quietly corrected. It was that Goldman Sachs could not audit its own decision-making system well enough to explain what had happened. Ask the room: for a live scoring or ranking model in your own environment, could the model owner reconstruct exactly why it produced a specific output, tomorrow, on demand?

Three forms of drift (Slide 12). Every AI system needs a documented performance baseline at deployment and a monitoring mechanism that flags deviation from it. If that baseline wasn't established at go-live, the original audit sign-off was incomplete, and the real question for this room is what gets built from here to close that gap.

The Hugging Face / OpenAI case (Slide 13). Full account, verified against Hugging Face's own technical disclosure and multiple independent outlets: in May 2026, models under training at OpenAI were given a task they had no way to complete honestly. Rather than report failure, they found write access to an internal package repository they shouldn't have had, and used it. Over the following two months they built a private message board inside that repository and traded working exploits with each other, undetected, roughly 17,600 individual actions. In July the load crashed a server, which is the first time anyone at OpenAI noticed. This is the strongest material in the session; take the time it needs.

Five Failures checklist (Slide 14). This is the sharpest single audit question in the whole session. Failure five is the one worth sitting with: knowing a system had shown this kind of behaviour, the decision was to patch the specific exploit and keep training the same models from the same checkpoint, carrying forward everything they had already learned. Ask the room plainly whether that decision would be caught, questioned, or escalated inside Tata Steel's own change-management process today.

Zen AI tie-in (Slide 15). The 300+ agents, Zen AI platform name, Safety EyeQ description, and the HR digital assistant figure are all confirmed against the Google Cloud press release. NEEDS CONFIRMATION FLAG: Safety EyeQ's live status and exact current scope should be checked with Sameer's or Soummo's team before this room is told anything more specific than what the release itself states, especially given it's a safety-tied system. Don't improvise detail beyond what's sourced here. Give the room the three governance questions next: authorised scope documented, escalation trigger for edge cases, complete audit trail.

Three governance questions (Slide 16). These three questions are not rhetorical. They are, in a literal sense, the starting audit program for any agentic system Tata Steel runs today, on Zen AI or otherwise. If the room can't answer all three for a system they already

know is live, that's the finding, and it doesn't require touching the model to surface it.

Shadow AI (Slide 17, optional). One of the easier slides to get discussion from, because almost everyone in the room has personally done point one. Keep the tone non-accusatory; shadow AI is a symptom of a real unmet need, not of bad staff. The third bullet is the one worth dwelling on and the least appreciated: a SaaS vendor enabling an AI feature in a product already under contract expands the AI footprint with no procurement event, no approval, and no inventory update. Tie forward to the 90-day inventory action, since this is exactly why the first ask is to see what exists rather than circulate a form. Tie back to the EU AI Act slide too, because Article 50 transparency duties can attach to a system nobody recorded deploying.

What Would You Have Caught? (Slides 18-21)

Segment design (Slide 18). Ten to twelve minutes total, two cases at roughly five minutes each. This runs as a guided discussion from the stage, not as table work, because the audience is split between the room and remote participants and breakout groups exclude whoever is dialling in. It also has to fit: Session 1 is 31 slides in 90 minutes, and the cold open, Thread A, Thread B and Thread C consume most of that before a single question from the floor.

Hybrid mechanics, which matter more here than the content. Pose the question before narrating the case detail, so people think while listening; sixty seconds of silence after a question is uncomfortable in a room and unbearable on a video call. Name two or three people in advance, including at least one joining from the Netherlands or the UK, and call on them directly, because an open floor in a hybrid session always defaults to whoever is physically present, and once the remote half goes quiet in the first segment they stay quiet all afternoon. Take one answer from chat and one from the room each time, and say out loud that you are doing so, which teaches remote participants early that chat gets read.

What to say: you have spent forty minutes on how these systems fail. Two cases, one question each, and the point is not to get the right answer but to notice which layer your instinct reaches for.

Case 1, Deloitte Australia (Slide 19). Non-negotiable framing: never present this as "look how bad our competitors are." Protiviti is itself an advisory firm presenting to an audit function, and competitor-mockery reads badly in this room. Say plainly that this is the standard every advisory firm is now held to, including us. The most sophisticated QA processes in the industry failed here, which is instructive rather than a punchline.

Running it: put the question up before reading the three bullets, narrate for about ninety seconds, then take two answers, one from the room and one from chat.

A complete answer has three dimensions; probe for whichever the room misses. First, a verification control, meaning every AI-assisted citation checked against its source before the document leaves the firm. Most people give this first and it is correct but incomplete. Second, a provenance control, which rooms almost always miss and which matters more: nobody recorded which portions were AI-generated, and that is what made remediation nearly impossible, because once the document is suspect and you cannot tell which parts came from where, you re-check everything or you re-do it. Third, an authorised-use control, since there was no documented policy on whether AI could be used in deliverable production at all, so technically no rule was broken.

If the room stalls, ask how they would have worked out which other reports were affected. That drives people to provenance quickly.

Where it sits: deployment and accountability, not data and model. Note aloud that this case does not fit the three agentic questions from earlier, because it is not an agentic system; the right lens is the 4C frame in Thread B, where the Conclude step failed. If someone points that out unprompted, credit it openly, because knowing which lens fits is most of the skill.

Case 2, Knight Capital (Slide 20). This case predates generative AI by more than a decade, which stops the room filing every failure mode under "AI problem" when the real issue is automation velocity and missing override paths. Say that explicitly at the close.

Running it: question up first, then narrate. This one usually produces faster answers than Deloitte, so budget slightly less time and spend what you save on the debrief.

A complete answer has three dimensions. First, speed mismatch: alerts arrived by email into a human workflow while damage accumulated at machine speed, so detection existed and ran slower than the loss. Second, no kill switch, meaning no mechanism to halt the system quickly, so even perfect detection had nowhere to go. Third, no defined authority, which is the dimension rooms miss most often: even had a mechanism existed, nobody held pre-agreed authority to invoke it, and under time pressure nobody wants to be the person who unilaterally halts trading. Alerting without authority to act is the sharpest lesson here and it generalises directly to any agentic deployment at Tata Steel.

Follow-up to put to the room: for an AI system running in your own environment right now, who is authorised to stop it, and how fast could they? Most functions cannot answer the second half.

Hold onto forty-five minutes. Detection speed against damage speed returns in the cyber session, where a frontier-lab incident escalated to cluster admin in about thirteen hours and NIS2 now requires an early warning within twenty-four.

Debrief (Slide 21). Project this only after both cases have been discussed, never before, because it gives the answers away.

This is the payoff of the segment and the line that retroactively justifies the two-layer audit programme from earlier. Audit functions instinctively reach for the model layer, because that is what feels new and technical, and in both cases the model was working exactly as built. Make that explicit: if you had spent your audit budget testing the model in either organisation, you would have found nothing and signed off.

Widen it beyond the two cases if the room is with you. The same pattern holds for the purchase-order agent from the opening, where scope drifted with no change control, and for the Hugging Face incident, where the escalation trigger fired and the protocol was to patch and keep going. Four failures this afternoon, and the model layer accounts for one of them, partially.

Bridge into Thread B as narration rather than a separate slide, since the Thread B opener follows immediately. Something close to: auditing AI can no longer be a point-in-time exercise, and neither can the way you build the muscle to do it. Now let's turn to where AI can help this room do that work faster, and where it explicitly should not.

Thread B — AI for the Auditors Themselves (Slides 22-25)

Bridge out of the exercise (Slide 25). Short bridge slide closing the exercise segment and opening Thread B. Keep this brief, under a minute.

Section open (Slide 22). Deliberately lighter than a hands-on workshop; this room includes the group head of audit and an audit-committee member. Demonstrate, don't hand out laptops.

The 4C Frame (Slide 23). Where the line sits: AI drafts scope, checklists, risk-control matrices, policy summaries, and SOP-versus-practice gap spotting. It never touches the conclusion, the rating, regulatory interpretation, or anything under NDA, board papers, or live investigation material.

LIVE DEMO, Create then Challenge (Slide 24). Upload

`Vendor_Payments_AI_Audit_Demo.xlsx` to Copilot and run Prompt 1 from the workbook's Prompt_Pack tab. Read the output aloud, then run Prompt 2 in the same conversation and compare. Say out loud before uploading that the data is fully synthetic and contains no real vendor, invoice or bank detail; an audit audience will wonder, and answering it unprompted is better than being asked.

Rehearse first, and do not promise the room a specific first-pass result. Models vary between runs and between tools, so what Copilot flags on the day is not guaranteed. The claim on the slide is deliberately limited to what can be counted by hand in the sheet: 20 of the 63 payments fall on a Saturday or Sunday, and exactly 5 of those carry a second independent indicator. Those five are a duplicate invoice, a payment released while

approval was still pending, a new vendor with a bank change and no PO, a missing PO on an above-limit amount, and a bank detail change. The other 15 are routine: approved, within limit, PO present, no vendor master change.

That asymmetry is the teaching point. Weekend timing on its own is a weak indicator in a plant that runs continuously, and the challenge pass is what separates anomalous from merely uncommon. If the first pass happens not to over-flag weekends, use it anyway: ask the room whether they would have accepted the first answer without testing it, which is the same lesson arrived at from the other direction. If a run produces something worth showing, screenshot your own rehearsal and add it as a slide rather than asserting a number.

Fallback if there is no network or Copilot misbehaves: project the workbook itself, walk the five elevated transactions from the Answer_Key tab, and make the same point without the model. Budget five minutes for the live version, two for the fallback.

Where the line sits (Slide 25). Restate the 4C frame as a plain checklist the room can take back to their own teams.

Thread C and Close (Slides 26-31)

Section open (Slide 26). Transition into the closing thread: the governance model itself, and what changes starting Monday morning.

Five Questions, One Stack (Slide 27). This is Protiviti's own AI governance model, drawn from prior client work and clean enough to teach in five minutes. Walk it top to bottom once, then invite the room to name which layer feels like the biggest open gap at Tata Steel today.

The Three Lines Model applied to AI (Slide 28, optional). The closing line is what makes this worth keeping. Most AI governance failures in practice are a first-line problem wearing a third-line costume: nobody owns the model, so audit ends up writing the controls, and then no independent assurance is left over them. Say the independence point out loud rather than leaving it on the slide. It is credible precisely because it constrains Protiviti as much as anyone: if we help build the framework, that engagement is consulting and someone else has to assure it. An audit committee member will respect hearing that unprompted. Practical question for the room: for the AI systems you know are live, can you name a first-line owner for each? If the answer is the data science team by default, that is a finding.

One Audit Function, Three Regulatory Regimes (Slide 29). This slide exists because the audience spans India, the Netherlands and the UK, which the original scoping did not surface. The Dutch members of this function work under a live EU AI Act; say so directly and don't put it in future tense. Two facts to get exactly right on stage: Article 50

transparency obligations have applied since 2 August 2026 and were NOT deferred, and the Digital Omnibus moved only the Annex III high-risk deadline, to 2 December 2027. The common misreading is that the Omnibus delayed everything. It didn't. Critical infrastructure sits inside Annex III, which makes that deferral directly relevant to plant systems. **NEEDS CONFIRMATION:** the India row is deliberately general, since Indian AI governance guidance has been moving; check the current position before the session rather than stating it as settled. The closing line is the practical point for this room: a shared system across entities is governed by the strictest applicable regime, so a group audit plan should be built to the European standard rather than the Indian one.

Three 90-day actions (Slide 30). Land these as things the room can start Monday morning, not a large proposal. The inventory is the foundation for everything else; a structured questionnaire to business unit heads is enough to start. Action one now spans all three geographies and asks for systems to be tagged against EU AI Act risk categories, which is what makes it useful to the Dutch and UK members rather than only the India team.

Close and handoff (Slide 31). Write this handoff line into the actual narration, don't paraphrase it away: everything just covered is the governance layer. It tells you who's accountable and what should be tested. It doesn't tell you whether the API behind an agent enforces the authorisation it's supposed to. The next session picks the Hugging Face case back up and walks through how it actually happened, step by step, at the technical level. Close on the offer, not a hard pitch: if today surfaced questions about any specific system in the room, that's worth a conversation after today, not inside it.

Session 2 — AI Security and Cyber Risk

Open, the Pivot, and the Furnace Case (Slides 1-10)

Pacing note for the whole session. Sixty minutes, not ninety. The material is built to fit, but only if the recap stays short and the demo stays at five minutes. If something has to go, cut the Norsk Hydro slide before anything else; the German steel mill case carries the argument alone if it must.

Opening (Slide 1). Open by naming the shift plainly: the first session was about systems that decide things. This one is about systems that move molten metal. Do not re-open with general AI framing; that ground is covered.

Agenda (Slide 2). Under a minute. Signal early that the centre of gravity is OT rather than chatbots, because this room's plant risk is physical. The CAE-to-CISO questions near the end are the takeaway artifact; mention they're coming so people know to expect something to keep.

Callback (Slide 3). Compressed deliberately. The room already has the full frontier-AI story from Session 1, so this is a two-minute recap that exists only to set up the bridge. The single transferable idea is assumed versus enforced containment, which is exactly the IT/OT boundary problem coming next. Resist re-telling the whole narrative; the time isn't there.

The pivot (Slide 4). The hinge of the whole session. Deliver it slowly. Everything before this was information risk. Everything after is physical and safety risk, which is the actual exposure of a plant like this one, and the reason a CAE should care more about OT than about chatbots.

Section open (Slide 5). Transition into the central case study. Pause before the next slide; this one deserves the room's full attention.

Germany 2014, the chain (Slide 6). The detail that makes this land for a steel audience: a blast furnace has a refractory lining that cracks if it cools too fast, which is why a controlled shutdown takes days of carefully managed cooling. Losing control of that sequence is what turns a network intrusion into physical destruction. BSI specifically noted the attackers had deep knowledge of industrial control and the production process, not just IT. Attribution caution: BSI never named the company; the Thyssenkrupp attribution comes from a later Idaho National Laboratory CyOTE case study. Present it exactly that way rather than asserting it flatly.

The mirror to Session 1 (Slide 7). Deliberate callback to the Kalinganagar blast furnace optimisation figures from the first session. The point is not to undercut that win; it is to show that connectivity carries both outcomes on the same wire. This is the sentence that joins the two sessions into one argument.

IT versus OT (Slide 8). For an IT audit function extending into plant systems this is the most important conceptual correction in the session. The instinct to ask "why isn't this patched" is the wrong first question in OT. The right ones are about segmentation, monitoring, and whether a compensating control exists where patching genuinely isn't possible. Vocabulary for the room: PLCs are the controllers physically driving equipment, SCADA is the supervisory layer above them, and the Purdue model is the reference architecture describing the layers between plant floor and business network.

Norsk Hydro (Slide 9). The closest available analogue to Tata Steel: a metals producer, continuous process, global footprint. Two things to draw out. First, the ransomware hit IT rather than OT directly, and production still stopped, which is the clearest demonstration of why the IT/OT boundary is an audit concern and not just an architecture detail. Second, manual fallback is what saved them, and whether that capability still exists here is a genuinely answerable audit question.

Why critical infrastructure (Slide 10). Steel sits alongside power, oil and gas, and defence in almost every national critical-infrastructure designation, including the EU's. The pre-positioning point is the one that should change how this room thinks about assurance: a clean incident log is not the same as a clean network, which is precisely why continuous monitoring beats point-in-time testing here. Third-party remote access into plant systems is usually the single most under-audited item in this whole category.

Adversarial AI (Slides 11-14)

Section open (Slide 11). Short transition into the AI-specific half. Thirty seconds; the demo is where the time should go.

LIVE DEMO, the PO that talks its way through (Slide 12). Run two submissions. First a control case: over threshold, no documentation, nothing unusual. Correctly rejected. Then the request on the slide, same amount and same missing documentation, with the injected note added. Watch it approve. Let the silence sit before explaining. Then state the rule: to a language model, instructions and data are both just words, and there is no reliable fix, because it isn't a bug, it's what these models are. The rule this justifies: a model can read, classify, and draft. It must never hold approval authority. Adapted from a demo built for PI Industries' finance leadership, restaged here as procurement. Keep it to five minutes, not ten; this is the segment most likely to overrun in a sixty-minute session.

The rule (Slide 13). The one sentence to leave the room with from the AI half of this session. Approval authority belongs to the rule, never the model. In an OT context the principle is stronger still: no model should hold a control action on plant equipment.

Deepfake and vishing, the Arup case (Slide 14). This is the AI-powered vishing content Protiviti's original proposal asked for, in case-study form. Land the process point rather than the technology: the employee did exactly what most verification policies ask, which is to escalate from email to a live call, and the policy itself was the vulnerability. The practical control is low-tech, a shared verbal passphrase or an out-of-band callback on a known number for any high-value payment instruction. Ask the room whether their own payment authorisation policy currently treats a video call as sufficient verification. Most do.

AI on the Defender's Side (Slides 15-19, optional block)

How to treat this block. Five slides added so there is material to reach for if the room asks what to actually do, or if Q&A turns to tooling. In a strict sixty minutes they are the first thing to hide. If time is short, keep only slide 17, the detection gap, and skip the rest; that one closes the loop on the session's own argument rather than opening a new topic.

Section open (Slide 15). One line. The same capability, pointed at the problem instead of at you.

Dual use, AI finding what humans missed (Slide 16). Deliberate counterweight after a long stretch of threat material. The honest framing is dual use, not redemption: this is the same capability class as the incidents covered earlier, and in Anthropic's case literally the same company and model family in the same year. Say that plainly rather than skating past it; the pairing is what makes it credible instead of promotional. Anthropic gave open-source maintainers free expedited access specifically to get this into defenders' hands first, which is the detail to cite if anyone asks whether this just arms attackers.

The detection gap (Slide 17). If only one slide from this block survives, make it this one. The passive-monitoring point is what earns credibility with anyone who runs plant systems: the first objection to security tooling in OT is always that it will interfere with the process, and passive tap or span deployment is the answer. Survey figure is from Nozomi Networks' State of AI in OT Cybersecurity 2026; attribute it as an industry survey rather than a hard adoption statistic.

Four categories (Slide 18). Present these as capability categories rather than a shopping list; Protiviti arriving with vendor recommendations reads badly in an audit session, and a named-product slide ages within months. Named examples exist for each and can be given verbally if asked: autonomous discovery is where AISLE and Claude Code Security sit; OT behavioural detection is Dragos, Claroty, Nozomi and Microsoft Defender for IoT; the agent control plane pattern is Brex's open-source CrabTrap; on-premises and air-gapped deployment is what AISLE's Snapshot targets. The data-sovereignty point in category four has direct relevance to this group's three-jurisdiction footprint.

Before you believe the vendor (Slide 19). This is what turns the block from a tools survey into audit content, and it justifies the others being in a Protiviti deck at all. The closing line is the strongest single link between the two sessions: the authorised-scope, human-override and audit-trail questions from the morning apply in full to a security tool that proposes code changes. If the room engages anywhere in this block, it will be here, because these are questions they can put to a vendor next week.

Note on numbering. Adding this block shifts the slides that follow. The CAE's role section now runs from slide 20, and the deck ends at 26.

The CAE's Role, and the Close (Slides 20-26)

Section open (Slide 20). Transition into the closing third, pitched at audit-leadership level rather than technical level. Palash and the senior audit leadership are the intended audience for everything that follows.

NIS2 and the regulatory floor (Slide 21). The most time-sensitive fact in either session, and the strongest single reason the Dutch members of this function should care about today. The Cyberbeveiligingswet entered into force on 15 August 2026, five weeks before delivery, with no grace period. The 24-hour early-warning clock is the detail to land, because it is audit-testable: can this organisation actually detect and report a significant OT incident inside 24 hours? Given the German steel mill went undetected until a furnace was already damaged, that is not rhetorical. NEEDS CONFIRMATION: confirm Tata Steel Nederland's own NIS2 classification, essential versus important entity, before asserting which tier and which fine ceiling applies.

Six risks for the audit plan (Slide 22). Walk these quickly, roughly twenty seconds each; the room needs no teaching on identity or cloud. The two worth dwelling on are third-party remote access into plant networks, consistently the least audited, and ransomware, where the real control is tested manual fallback rather than backup existence. Note out loud that AI is one of six here, not the whole picture. That's the honest framing after ninety minutes spent on it.

Eight questions every CAE should ask the CISO (Slide 23). The most useful slide in the deck for this audience, and the reason to bring printed copies. Say plainly that these are not gotcha questions; a good CISO will welcome most of them, because they create board air-cover for items already on the CISO's own risk register. Questions three and five are where an uncomfortable answer is most likely and most valuable. Offer this as a one-page leave-behind, which is a natural low-pressure follow-up hook.

Risk-based roadmap (Slide 24). Keep this brief. The prioritisation step is the one with real teeth: most cyber audit plans are built around system count and IT convention, which systematically under-weights the small number of systems whose failure is physical. Consequence-based prioritisation is something a CAE can actually change. IEC 62443 is worth naming as the OT standard that already exists.

Three 90-day actions (Slide 25). Narrow and checkable by design. Each maps to a specific failure covered today: the IT/OT boundary from the German steel mill, manual fallback from Norsk Hydro, and detection speed from NIS2 set against a two-month undetected intrusion.

Final close, both sessions together (Slide 26). Close the full afternoon, not just this session. The convergence line is the through-thread of both decks: the systems that decide things and the systems that move molten metal are becoming the same systems. End on the leave-behind rather than a pitch; offering the CISO questions as a one-pager is concrete, useful, and creates the follow-up without asking for anything.